Pericope ERM - Complete Platform Feature Manual

Product: Pericope Enterprise Risk Management & GRC Suite

Platform Version: 3.5 (Enterprise Edition)

Authors: Srivatsan B, Raja Vishnu, Rithvik R, Niranthar M Javagal

Institutional Guide: Prof. Veena S, Department of CSE, Atria Institute of Technology

1. Platform Overview & Design Philosophy

Pericope ERM is a full-stack, enterprise-grade Governance, Risk, and Compliance (GRC) software suite. It centralizes risk registers, internal controls, KRI telemetry, and audit workpapers into an auditable system of record.

- **Dual Qualitative & Quantitative Scoring:** Bridges 5x5 heatmap coordinates with monetary Single Loss Expectancy (SLE = S x $10,000).
- **Resilience-First Design:** Bounded 8-second circuit breakers with an in-memory shadow store fallback that guarantees zero user interface freezing.
- **Audit Non-Repudiation:** Real-time user attribution and Oracle autonomous transaction triggers (PRAGMA AUTONOMOUS_TRANSACTION).

2. Identity, Authentication & Role-Based Access Control (RBAC)

2.1 Multi-Mode Authentication Portal (/login)

The authentication screen provides three distinct sign-in methods:

- **Persona Quick-Select Mode:** 1-click access to 5 pre-configured enterprise job roles for demonstration and RBAC validation.
- **Corporate Credentials Mode:** Standard email/password entry with client-side and server-side validation.
- **Enterprise Single Sign-On (SSO):** Simulated federated OIDC / SAML 2.0 integration (Microsoft Entra ID, Okta).

2.2 The 5 Enterprise Roles & Access Permissions Matrix

Role	Default Persona	Department	Permission Scope	Capabilities & Boundaries
:---	:---	:---	:---:	:---
Administrator	Srivatsan B	Executive Risk Office	`CREATE`, `READ`, `UPDATE`, `DELETE`, `ADMIN`	Full control across all 25 modules. Manage user roles, system parameters, and database sync.
Risk Manager	Priya Sharma	Finance & Treasury	`CREATE`, `READ`, `UPDATE`, `DELETE`	Operational GRC lead. Approve mitigation plans, validate controls, configure KRI limits.
Assessor	Anthony Muller	Global Operations	`CREATE`, `READ`, `UPDATE`	Business unit risk owner. Create risks, evaluate likelihood/ impact. No destructive delete.
Auditor	Lin Wei	Internal Audit	`READ` ONLY	Independent reviewer. Access all records, testing workpapers, and immutable audit logs.
Viewer	Karen Diaz	Executive Office	`READ` ONLY	Executive oversight. View dashboards, heatmaps, and generate board PDF exports.

2.3 User Attribution & Audit Headers

Every mutating API request attaches `X-User-Id`, `X-User-Name`, and `X-User-Role` headers populated from the authenticated session and persisted directly to the audit log.

3. Executive Cockpit & Dashboard (/dashboard)

The Executive Dashboard provides an immediate command-center view of the organization's risk posture:

- **4 Operational Metric Tiles:**
- **Active Risks:** Real-time portfolio totals with high/critical breakdown.
- **Single Loss Expectancy (SLE):** Aggregate monetary exposure baseline ($/Rs).
- **Control Coverage:** Percentage of cataloged risks with operating mitigating controls.
- **RCSA Stage Completion:** Progress across active quarterly assessment cycles.
- **Trailing Risk Velocity Chart:** Interactive 6-month area chart modeling risk registration velocity versus closure rates.
- **Risk Allocation by Function:** Progress bars displaying risk distribution across IT, Finance, Operations, and Compliance.
- **Live RCSA Case Ledger:** High-density table of recent risk statements with immediate deep-link navigation.

4. RCSA Assessment Lifecycle Hub

4.1 Step 1: Cycle Provisioning & Setup (/rcsa/provisioning)

- **Create Assessment Cycles:** Define quarterly assessment scopes (e.g. `RCSA-FIN-2026-001`), department targets, start/end dates, and assign risk champions.
- **Industry Starter Packs:** 1-Click demo seeding for:
- *Fintech & Banking Pack* (SWIFT settlement latency, AML/KYC review, payment processor availability).
- *SaaS & Cloud Security Pack* (SOC 2 Type II readiness, AWS multi-region failover, GDPR data pipeline).
- *Healthcare Compliance Pack* (HIPAA electronic health records security, clinical supply chain).

4.2 Step 2: Risk Identification & Cataloging (/rcsa/identification)

- **Risk Statement Entry:** Register operational risk scenarios with Likelihood (1-5) and Impact (1-5) ratings.
- **Automatic Single Loss Calculation:** System dynamically computes SLE = L x I x $10,000.

4.3 Bulk Excel/CSV Migration Wizard

- **Download Sample Template:** Generates `pericope_risk_register_template.csv`.
- **Drag-and-Drop Import:** Parses existing spreadsheet columns (Statement, Category, Department, Likelihood, Impact, Owner).
- **Multi-Row Preview Table:** Validates data before executing batch database insertion.

4.4 Step 3: Assessment Details & Risk Context (/rcsa/provisioning/[id])

- **Dedicated Assessment View:** Inspects an individual assessment cycle, displaying its specific metadata, active champion, total financial exposure, and connected risk records.
- **Direct Control Mapping Trigger:** Each risk has a **"Map Controls →"** action navigating directly to the control evaluation screen.

4. RCSA Lifecycle Hub (Continued)

4.5 Step 4: Internal Control Mapping & Residual Scoring (/rcsa/provisioning/[id]/controls/[riskId])

- **Control Tagging:** Map preventive, detective, and corrective controls to a specific risk scenario.
- **Effectiveness Scoring:** Rate Design Effectiveness (1-5) and Operating Effectiveness (1-5).
- **Live Residual Risk Calculation:** Displays immediate exposure reduction percentage (e.g. 75% reduction).

4.6 Step 5: Risk Mitigation & Department Overview (/rcsa/mitigation)

- **Departmental Accordion Groups:** Grouped view of all risks by business unit (Finance, IT, Procurement, Retail, Inventory).
- **Individual Mitigation Profile (/rcsa/mitigation/[id]):** In-depth risk mitigation screen showing linked controls, residual score step-down, and action plan creation.

4.7 Step 6: Risk Monitoring & Action Plans (/rcsa/monitoring, /monitoring/*)

- **Action Plan Roadmap:** Track remediation milestones, assigned owners, target completion dates, and completion percentages (0-100%).

5. Risk Analytics & Mathematical Engines

5.1 5x5 Enterprise Risk Heatmap Matrix (/heatmaps)

- **Bi-Axial Coordinate Grid:**
- **Vertical Y-Axis (Likelihood):** `5 - Almost Certain` down to `1 - Rare`.
- **Horizontal X-Axis (Impact):** `1 - Insignificant` up to `5 - Severe`.
- **Multi-View Modes:** Instant toggle between **1. Inherent Exposure**, **2. Residual (Post-Control)**, and **3. Risk Velocity**.
- **Interactive Cell Inspection:** Click any cell with active numbers to open a modal listing the underlying risk records.

5.2 Inherent & Residual Risk Evaluation (/assessments/inherent, /assessments/residual)

- **Root Cause & Causal Factor Analysis:** Capture detailed qualitative narratives, data sources, and affected stakeholders.
- **Mathematical Step-Down:** Compares gross inherent position against net residual exposure after control mitigation.

5. Mathematical Engines & Quantification (Continued)

5.3 Key Risk Indicators (KRI) Telemetry Engine (/kri, /kri/matrix, /kri/configuration)

- **Threshold Color Bands:** Green (Normal), Amber (Warning Limit), Red (Critical Breach).
- **Live Telemetry Simulator:** Click the update icon on any indicator to input a new reading (e.g. `14.5` hrs) and observe the real-time status change, trend line peak, and audit log generation.

5.4 Open FAIR Monte Carlo Simulation Engine (/scenario, oracleService.ts)

- **10,000-Iteration Probabilistic Engine:**
- Loss Event Frequency (LEF) modeled as a **Poisson distribution** (λ = (L / 5) * 2.5).
- Loss Magnitude (LM) modeled as a **Lognormal distribution** (μ, σ).
- Outputs **Annualized Loss Expectancy (ALE)** and **95% Value at Risk (VaR 95)**.

5.5 Quantitative Risk Formulas Reference Sheet

1. Qualitative Composite Score:

```
S = L × I      L, I ∈ \{1, 2, 3, 4, 5\}    ⇒    S ∈ [1, 25]
```

- **Low:** 1 ≤ S ≤ 7
- **Medium:** 8 ≤ S ≤ 11
- **High:** 12 ≤ S ≤ 15
- **Critical:** 16 ≤ S ≤ 25

2. Single Loss Expectancy (SLE):

```
SLE = L × I × \$10{,000    (USD)
```

3. Multi-Factor Control Effectiveness & Residual Risk:

```
η = {Design Effectiveness (1–5) × Operating Effectiveness (1–5){25 ∈ [0.04, 1.0]
```

```
L_{res = max≤ft(1, \; round≤ft(L_{inh × (1 − 0.7 × η)\right)\right)
```

```
I_{res = max≤ft(1, \; round≤ft(I_{inh × (1 − 0.5 × η)\right)\right)
```

```
Residual SLE = L_{res × I_{res × \$10{,000
```

6. Governance, Controls & Approvals

6.1 Advanced Control Library (/control-library)

- Central register of internal controls.
- Filter by type: *Preventive*, *Detective*, *Corrective*, *Compensating*.
- Tracks testing frequency (*Continuous*, *Daily*, *Weekly*, *Monthly*, *Quarterly*, *Annual*), control nature (*Automated*, *Manual*, *Hybrid*), and regulatory frameworks (*ISO 27001*, *SOX 404*, *GDPR*).

6.2 Risk Appetite & Boundary Framework (/risk-appetite, /appetite/framework)

- Define organizational appetite statements by domain (*Strategic*, *Financial*, *Operational*, *Compliance*, *IT & Cyber*, *Vendor*).
- Posture definitions (*Averse*, *Cautious*, *Open*, *Hungry*) with numerical tolerance limits.

6.3 Maker–Checker Approval Workflows (/workflow)

- Multi-step approval chains enforcing Segregation of Duties (SoD).
- Role-restricted Approve and Reject actions with timestamped audit notes.

6.4 Policy Management Center (/policy)

- Central governance library with version numbering (e.g. `v3.2`), effective dates, renewal cycles, and employee acknowledgment rates (%).

7. Enterprise Risk & Operational Resilience

7.1 Third-Party Risk Management (TPRM) (/vendor-risk)

- Tiered vendor register (*Critical*, *High*, *Medium*, *Low*).
- Tracks contract spend ($), risk scores (1-100), due diligence dates, and open audit findings.

7.2 Incident & Loss Event Management (/incidents)

- Loss event logging linked directly to enterprise risk IDs.
- Tracks severity (*Critical*, *High*, *Medium*, *Low*), status (*Open*, *Investigating*, *Mitigated*, *Closed*), root cause, and corrective actions.

7.3 Business Continuity Planning (BCP / DRP) (/bcp)

- Disaster recovery plans with Recovery Time Objective (RTO) and Recovery Point Objective (RPO) in hours.
- Tracks annual testing cadence and overdue review notices.

7.4 Scenario Analysis & Stress Testing (/scenario)

- Forward-looking stress testing lab modeling macro shocks (e.g. 20% FX devaluation, 24-hr cloud region outage).
- Compares baseline loss against stressed loss.

8. Audit, Administration & Reports

8.1 Immutable Audit Trail (SOX 404) (/audit-trail)

- Chronological event ledger recording: Timestamp, Actor Name, Actor Role, Action Type (`CREATE`, `UPDATE`, `DELETE`, `APPROVE`, `ROLE_CHANGE`), Target Entity, Description, and Result.
- 1-Click CSV Export.

8.2 User & Security Administration (/users)

- Administrative console to create users, assign job roles, and toggle account activation.

8.3 System Configuration (/settings)

- Organization profile parameters, notification alert routing, session timeout limits, and data retention compliance windows.

8.4 8-in-1 Executive Board Risk Reports & PDF Generator (/reports)

The platform includes 8 connected, dynamic report templates:

- **Executive Board Risk Committee Pack (RPT-001):** Board-level summary, $SLE exposure, top high-exposure risks, and KRI thresholds.
- **RCSA Assessment Lifecycle Summary (RPT-002):** Departmental progress and stage completion.
- **SOX Section 404 Control Test Workpapers (RPT-003):** ICFR testing matrix with design and operating effectiveness scores.
- **Immutable Audit Trail Ledger (RPT-004):** Complete chronological system event log.
- **Key Risk Indicator (KRI) Threshold Register (RPT-005):** Operational telemetry threshold scorecard.
- **Control Effectiveness & Residual Risk Report (RPT-006):** Inherent vs Residual step-down matrix and financial reduction metrics.
- **ISO/IEC 27001 Security Evidence Pack (RPT-007):** Annex A information security control implementation evidence.
- **Third-Party Vendor Risk Assessment (RPT-008):** TPRM portfolio review and spend criticality inventory.
- **1-Click PDF Export:** Custom print stylesheets strip all browser navigation and headers, rendering only the clean, full-width executive report.

9. Resilient 3-Tier Backend & Oracle Database Architecture

9.1 Technical Specifications:

- **Frontend:** Next.js 15 App Router · React 19 · Tailwind CSS · TanStack Query
- **BFF API Gateway:** Node.js Express API · Bounded 8s Timeout · In-Memory Shadow Store
- **Database:** Oracle Autonomous Database (ADW) · ORDS REST Gateway (48 Entities) · PL/SQL Autonomous Triggers (`PRAGMA AUTONOMOUS_TRANSACTION`)

9.2 The Shadow Store & Circuit Breaker Logic

```
Client Request ---> [ BFF Express Gateway (server.js) ]









                    (UI NEVER Freezes!)
| (8s Timeout Timer)
+-------------+-------------+
| (Success < 8s)            | (Timeout / Failure)
v                           v
[ Oracle ADW / ORDS ]        [ In-Memory Shadow Store ]
|                           | (nextId() synthetic UUID)
+-------------+-------------+



Returns JSON (200/201)
```

9.3 PL/SQL Autonomous Audit Trigger Fix

```
CREATE OR REPLACE PROCEDURE ERM_AUDIT_WRITE (









/
p_action IN VARCHAR2, p_entity IN VARCHAR2, p_entity_id IN VARCHAR2, p_desc IN VARCHAR2
) AS
PRAGMA AUTONOMOUS_TRANSACTION;
v_actor VARCHAR2(200);
BEGIN
v_actor := NVL(SYS_CONTEXT('USERENV','CLIENT_IDENTIFIER'), USER);
EXECUTE IMMEDIATE 'INSERT INTO ERM_TRN_AUDIT_LOG (...) VALUES (...)';
COMMIT;
EXCEPTION
WHEN OTHERS THEN ROLLBACK; -- Swallowed: Audit failure NEVER breaks business DML
END;
```

10. Operational Startup & Verification Commands

10.1 Running the Stack:

- **Start BFF API Server (Terminal 1):**

```
node server.js
```

- **Start Next.js Frontend (Terminal 2):**

```
npm run dev
```

- **Execute Automated QA Test Suite (Terminal 3):**

```
node qa_test_suite.mjs
```

- **TypeScript Static Typecheck:**

```
npx tsc --noEmit
```

10.2 Automated QA Verification Results:

- **Composite Scoring Bounds:** Verified (1 to 25)
- **Qualitative Banding:** Verified (Low, Medium, High, Critical)
- **Single Loss Expectancy (SLE):** Verified ($10k per score point)
- **Multi-Factor Residual Formula:** Verified (eta weighting)
- **Open FAIR Monte Carlo Simulation:** Verified (10,000 iterations)
- **Anti-Junk Input Filter:** Verified (rejection of keyboard mash)
- **ORDS Response Normalizer:** Verified (lowercase mapping)
- **User Attribution Logging:** Verified (X-User-* capture)
- **LocalStore CRUD Lifecycle:** Verified (100% offline tolerance)

Pericope ERM · Enterprise Risk Management · Confidential © 2026